Ticket: CampusCart Auth (JWT lite)

Customer: CampusCart catalog screen
Need: Anyone may **browse** snacks (`GET /products`). Only a **logged-in** user may **add** a snack (`POST /products`). Staff register and login with email + password. The API returns a **JWT**. POST sends `Authorization: Bearer <token>`. Passwords are **BCrypt hashes** in MySQL — never the raw string.

Teaching-order: Keep kit 18 persistence (entity, repository, DTOs, `@Valid`, lite 400). Add `spring-boot-starter-security`, `AppUser`, register / login, **BCrypt**, **JWT** (jjwt), `SecurityFilterChain` (Boot 3 — **not** `WebSecurityConfigurerAdapter`). GET catalog stays public. POST catalog needs a token → **401** without it. Secret from env (`JWT_SECRET`, 32+ chars). `jakarta.*`. No OAuth2 / refresh tokens / admin roles. No Lombok. CORS Stretch only (**Later —** React).

Each of `starter/`, `broken/`, and `solution/` is a Maven tree. Open the folder that contains **`pom.xml`**.

Starter

Product list / get / create DTOs are already filled (kit 18). Complete TODOs in `AppUser`, `SecurityConfig`, `JwtService`, `JwtAuthFilter`, and `AuthController`. Export env from `.env.example` including **`JWT_SECRET`**. Import `CampusCart_Auth_v1.postman_collection.json`.

Broken

Raw password saved. `NoOpPasswordEncoder`. `permitAll` on every URL. Fake JWT string. Secret and MySQL password literals in yml. Filter never reads `Authorization`. Fix until curl / Postman match Done when.

Postman

File: `CampusCart_Auth_v1.postman_collection.json`. **Import** in Postman. Variable `baseUrl` = `http://localhost:8080`. Run **Register** (or **Login**) before **Create product with Bearer**.

Run

```
# from kit root
export MYSQL_PASSWORD='your_lab_password'
export MYSQL_USER=root
export MYSQL_DATABASE=training_db
export JWT_SECRET='change_me_lab_jwt_secret_32chars!'

cd starter          # or broken / solution
mvn spring-boot:run
```

Second terminal:

```
curl -s -X POST http://localhost:8080/auth/register \
  -H "Content-Type: application/json" \
  -d '{"email":"priya@campuscart.in","password":"IdliDosa8"}'
# copy token from JSON

curl -s http://localhost:8080/products

curl -s -o /dev/null -w "%{http_code}\n" -X POST http://localhost:8080/products \
  -H "Content-Type: application/json" \
```

```
  -d '{"name":"Pani puri","priceInr":30}'
# expect 401

curl -s -X POST http://localhost:8080/products \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer PASTE_TOKEN" \
  -d '{"name":"Pani puri","priceInr":30}'
# expect 201
```

Done when

- [ ] `mvn spring-boot:run` starts (Tomcat + DataSource + Security)
- [ ] `POST /auth/register` → **201** JSON with `token` + `email` (no password field)
- [ ] Password in MySQL is a **BCrypt** hash (starts with `$2`), not `IdliDosa8`
- [ ] `POST /auth/login` with wrong password → **401**
- [ ] `GET /products` works **without** a token (**200**)
- [ ] `POST /products` without token → **401**
- [ ] `POST /products` with `Authorization: Bearer …` → **201**
- [ ] Duplicate register email → **409**
- [ ] `JWT_SECRET` and DB password are not literals in git
- [ ] Postman collection v1 imports; requests match the statuses above
- [ ] No OAuth2, refresh tokens, Lombok, or admin-role matrix required
- [ ] `target/` gitignored

Stretch

- `@CrossOrigin(origins = "http://localhost:5173")` — **not** Done when.
- Extra claim on JWT (e.g. `uid`) — not Done when.
- HTTP DELETE `/products/{id}` still authenticated — optional.
- **Later —** refresh tokens, OAuth2, role-based admin. **Later —** React login form.
- Lombok / records — optional, not in Done when.